PRÁCTICA 8 - ANÁLISIS DE TRÁFICO SSL/TLS Con Wireshark

Realizado por Unai García Blanco y Alberto García Martín

1. Instalar la utilidad wireshark y un capturador de paquetes.....2

2. Elegir una página segura y dos navegadores diferentes (preferiblemente que uno sea Mozilla Firefox). Conectarse a dicha página desde ambos navegadores y analizar la información intercambiada en la negociación (handshake).....2

3. Para cada una de las dos conexiones:..... 2

a. Se capturará en tráfico de red de la etapa de negociación (https) con la dirección IP de la página elegida. Filtrar convenientemente por IP del servidor y por protocolo TLS. Hacer captura de pantalla de los paquetes analizados con filtro aplicado y sin aplicar.....2

b. Seleccionar el paquete SSL/TLS, etiquetado Client Hello. Analizar los distintos campos. En el informe presentar la lista de 'ciphersuites' ofertados y extensiones soportados por el cliente como algoritmos de firma. Localizar el nombre del servidor de páginas y comprobar las direcciones IP de origen y destino del paquete..... 2

c. Seleccionar el paquete SSL/TLS, etiquetado Server Hello. Analizar los distintos campos. Ver los parámetros 'ciphersuites' elegidos por el servidor. ¿Qué lugar ocupa el 'ciphersuite' elegido en la lista del cliente? Comprobar las direcciones IP de origen y destino del paquete. Comprobar que el 'ciphersuite' mostrado con WireShark es el mismo que muestra el navegador..... 4

d. Solo en caso de la versión TLS 1.2, seleccionar los paquetes SSL/TLS Certificate y Server Hello Done. Del paquete Certificate, visualizar los distintos campos del certificado proporcionado. Comprobar que los valores de los campos Nombre común (CN) y Organización (O) visualizados en Wireshark coinciden con los visualizados con el visor del navegador usado para la captura. Del paquete etiquetado Server Hello Done, mostrar los distintos campos.....6

4. Ver si ha habido diferencias en la elección de parámetros criptográficos dependiendo de los navegadores..... 9

5. Visualizar del minuto 40:00 al 53:00 (intervención de Ramón Onrubia) en el vídeo (*). ¿Puede deducirse que con Wireshark pueden obtenerse fácilmente contraseñas de usuarios de un equipo?. Razone según lo que se ve.....9

1. **Instalar la utilidad wireshark y un capturador de paquetes.**
2. **Elegir una página segura y dos navegadores diferentes (preferiblemente que uno sea Mozilla Firefox). Conectarse a dicha página desde ambos navegadores y analizar la información intercambiada en la negociación (handshake).**

Teniendo el entorno correctamente instalado, hemos elegido https://www.wikipedia.org/ como página web segura para realizar el análisis de tráfico de red.

3. **Para cada una de las dos conexiones:**

    a. **Se capturará en tráfico de red de la etapa de negociación (https) con la dirección IP de la página elegida. Filtrar convenientemente por IP del servidor y por protocolo TLS. Hacer captura de pantalla de los paquetes analizados con filtro aplicado y sin aplicar.**

Se han guardado correctamente las capturas de los paquetes. Se ha podido comprobar paquetes con distintos protocolos:

- **DNS:** Sistema de Nombres de Dominio, reconocimiento de la IP del servidor de Wikipedia.
- **TCP:** Protocolo de Control de Transmisión: permite la conexión dentro de una red de datos compuesta.
- **TLS:** Protocolo de Seguridad de la Capa de Transporte: protocolos criptográficos que proporcionan una conexión segura en la red.

    b. **Seleccionar el paquete SSL/TLS, etiquetado Client Hello. Analizar los distintos campos. En el informe presentar la lista de 'ciphersuites' ofertados y extensiones soportados por el cliente como algoritmos de firma. Localizar el nombre del servidor de páginas y comprobar las direcciones IP de origen y destino del paquete.**

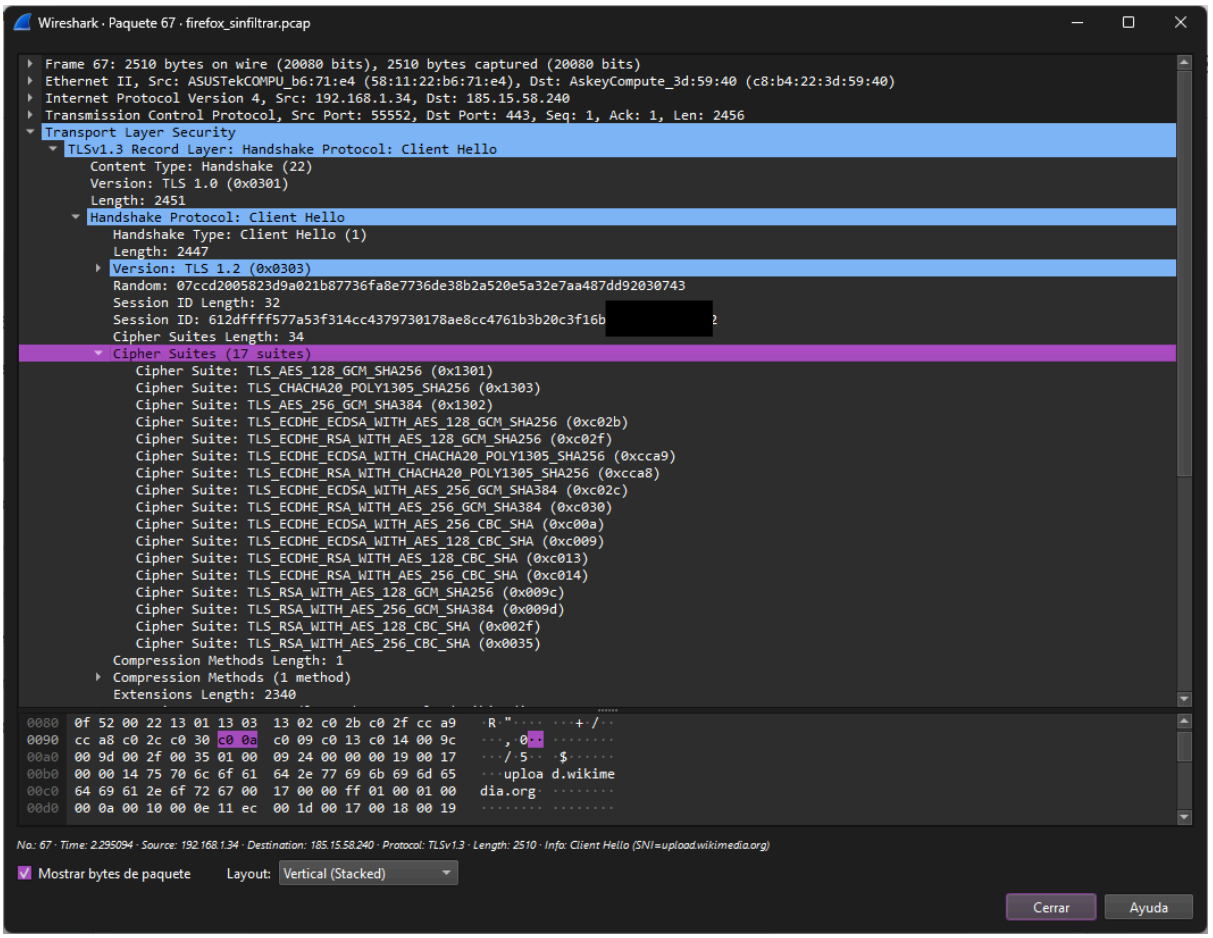
Vamos a analizar los distintos campos del protocolo TLS para Client Hello:

- Versión: TLS 1.2 (0x0303). Este campo indica que el servidor y el cliente usarán TLS 1.2.
- Random: Una secuencia aleatoria generada por el servidor para la negociación de la clave.
- Session ID: Identificador de sesión que puede ser reutilizado en futuras conexiones para mejorar el rendimiento.
- Cipher Suites: identifica la lista de algoritmos ofrecidos por el cliente. Los cipher suites ofertados son:

    - **1. TLS_AES_128_GCM_SHA256** (0x1301).
    - **2. TLS_CHACHA20_POLY1305_SHA256** (0x1303).
    - **3. TLS_AES_256_GCM_SHA384** (0x1302).
    - **4. TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256** (0xC02B).
    - **5. TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256** (0xC02F).
    - **6. TLS_ECDHE_ECDSA_WITH_CHACHA20_POLY1305_SHA256** (0xCCA9).
    - **7. TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256** (0xCCA8).
    - **8. TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384** (0xC02C).
    - **9. TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384** (0xC030).
    - **10. TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA** (0xC014).
    - **11. TLS_RSA_WITH_AES_128_GCM_SHA256** (0x009C).
    - **12. TLS_RSA_WITH_AES_256_GCM_SHA384** (0x009D).
    - **13. TLS_RSA_WITH_AES_128_CBC_SHA** (0x002F).
    - **14. TLS_RSA_WITH_AES_256_CBC_SHA** (0x0035).
    - **15. TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA** (0xC009).
    - **16. TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA** (0xC00A).
    - **17. TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA** (0xC013).

- Extensiones: busca extensiones soportadas, las extensiones son:
    - **Server Name:** upload.wikimedia.org.
    - **Extended Master Secret**: Refuerza la seguridad del secreto maestro.
    - **Renegotiation Info**: Información sobre posibles renegociaciones.
    - **Supported Groups**: Grupos soportados.
    - **EC Point Formats**: Formatos de puntos soportados para curvas elípticas.
    - **Application Layer Protocol Negotiation (ALPN)**: Protocolos negociados.
    - **Status Request**: Información del estado del certificado (OCSP).
    - **Delegated Credentials**: Soporte para credenciales delegadas.
    - **Key Share**: Métodos de intercambio de claves.
    - **Supported Versions**: Versiones soportadas:
    - **Signature Algorithms**: Algoritmos de firma soportados.
    - **PSK Key Exchange Modes**: Métodos de intercambio de claves PSK.
    - **Record Size Limit**: Límite máximo de tamaño del registro.
    - **Compress Certificate**: Soporte para certificados comprimidos.
    - **Encrypted Client Hello**: Extensión relacionada con datos encriptados.
    - **Pre-Shared Key (PSK)**: Clave precompartida para optimización de conexiones.

- Direcciones IP: lo podemos comprobar en el propio paquete.
    - Origen: 192.168.1.34 (cliente).
    - Destino: 185.15.58.240 (servidor).
- Nombre del servidor: podemos comprobarlo en el propio paquete (muestra la extensión SNI) o en el conjunto de extensiones. En este caso es upload.wikimedia.org.

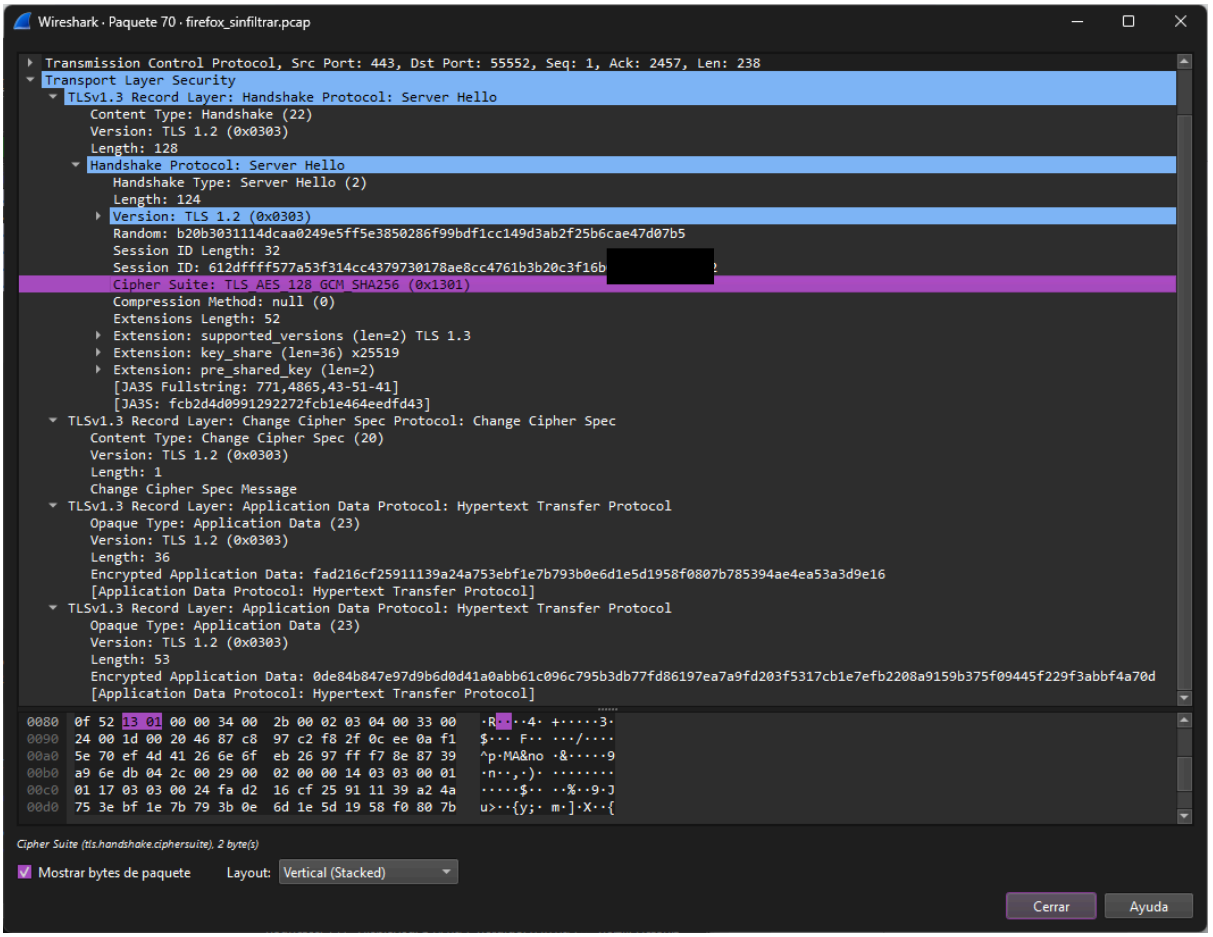


c. Seleccionar el paquete SSL/TLS, etiquetado Server Hello. Analizar los distintos campos. Ver los parámetros 'ciphersuites' elegidos por el servidor. ¿Qué lugar ocupa el 'ciphersuite' elegido en la lista del cliente? Comprobar las direcciones IP de origen y destino del paquete. Comprobar que el 'ciphersuite' mostrado con WireShark es el mismo que muestra el navegador.

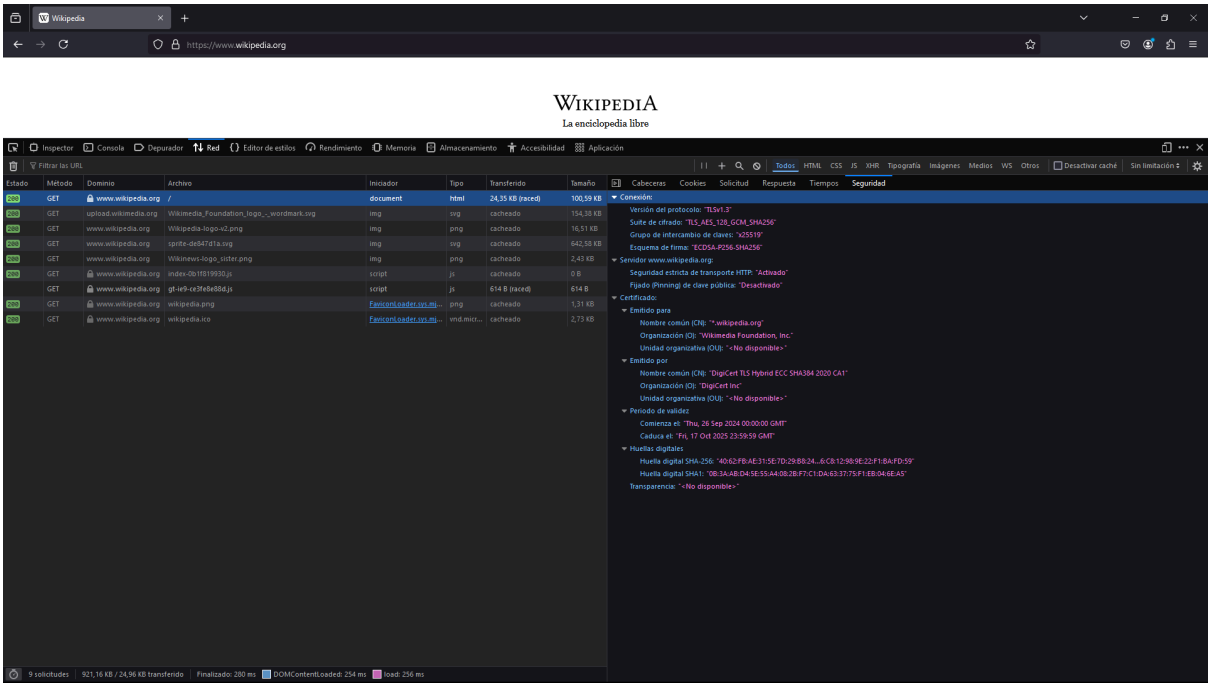
Vamos a analizar ahora el paquete Server Hello:

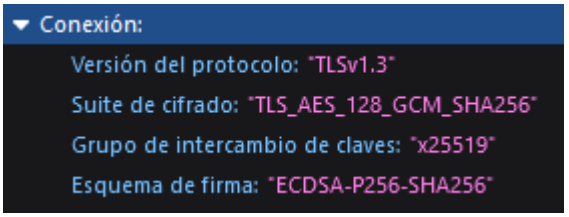
- Versión, Random y Session ID (igual que en Client Hello).
- Cipher Suite: **TLS_AES_128_GCM_SHA256 (0x1301)** fue el algoritmo de cifrado seleccionado por el servidor para asegurar las comunicaciones. Esto especifica:
    - Cifrado: AES de 128 bits en modo Galois/Counter (GCM).
    - Función hash: SHA-256.

- Compression Method: null (0) – Esto indica que no se usará compresión en esta sesión.
- Extensiones: busca extensiones soportadas, las extensiones son:
  - supported_versions (TLS 1.2 y TLS 1.3).
  - key_share (grupo x25519).
  - pre_shared_key (no se usó).
- Direcciones IP: lo podemos comprobar en el propio paquete.
  - Origen: 185.15.58.240 (servidor).
  - Destino: 192.168.1.34 (cliente).
- Posición del Cipher Suite en la lista del cliente: en este caso, el lugar exacto que ocupa TLS_AES_128_GCM_SHA256 (0x1301) en la lista enviada por el cliente es en la **posición 1.**



Vamos a comprobar ahora que el ciphersuite mostrado con Wireshark es el mismo que muestra el navegador, nos dirigimos por tanto a la web de Wikipedia. Al apartado de “red”. Seleccionamos la página a la que hemos accedido y posteriormente seleccionamos el apartado de seguridad:

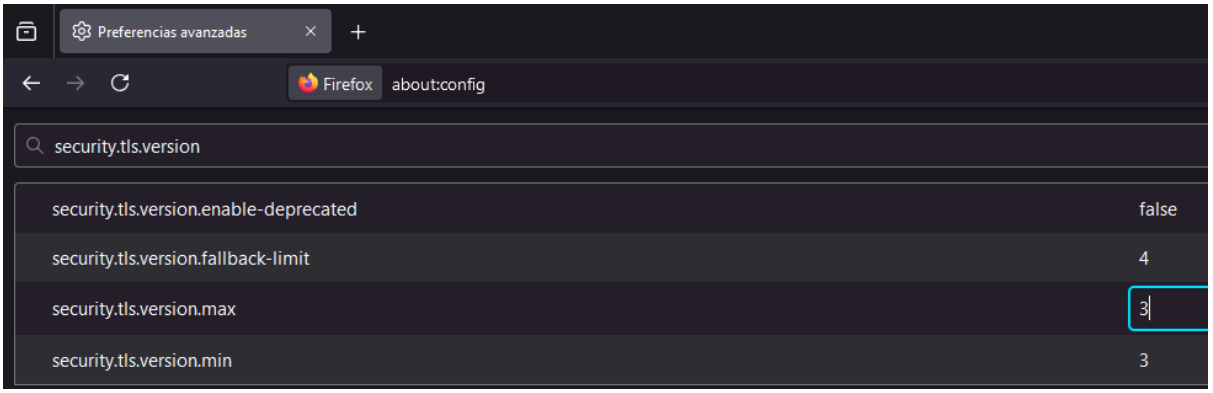




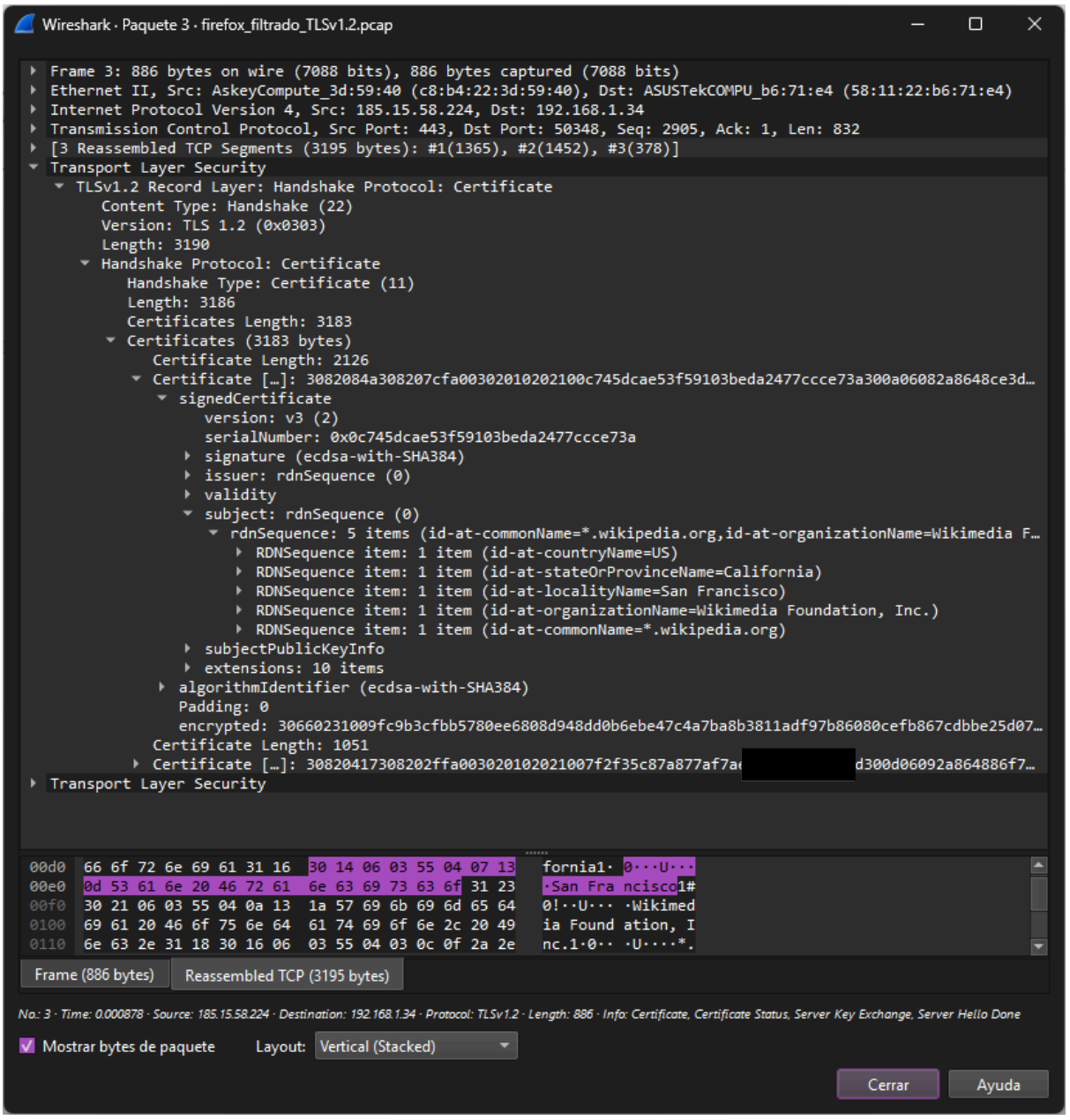
Podemos comprobar que el Suite de cifrado es el TLS_AES_128_GCM_SHA256 (0x1301) visto previamente.

d. Solo en caso de la versión TLS 1.2, seleccionar los paquetes SSL/TLS Certificate y Server Hello Done. Del paquete Certificate, visualizar los distintos campos del certificado proporcionado. Comprobar que los valores de los campos Nombre común (CN) y Organización (O) visualizados en Wireshark coinciden con los visualizados con el visor del navegador usado para la captura. Del paquete etiquetado Server Hello Done, mostrar los distintos campos.

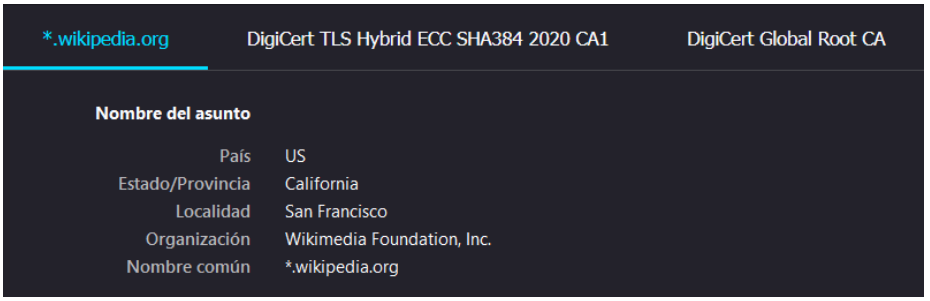
Para poder realizar este apartado, cambiamos el parámetro del navegador Firefox security.tls.version.max al valor 3 que es el correspondiente a TLS 1.2. Para posteriormente reiniciar el navegador.



Ahora vamos a volver a analizar los paquetes y comprobar el paquete general Certificate, Server Hello Done, en el apartado certificate, nos dirigiremos hasta el certificado, y de allí al apartado subject hasta encontrar la información del certificado en rdnSequence:



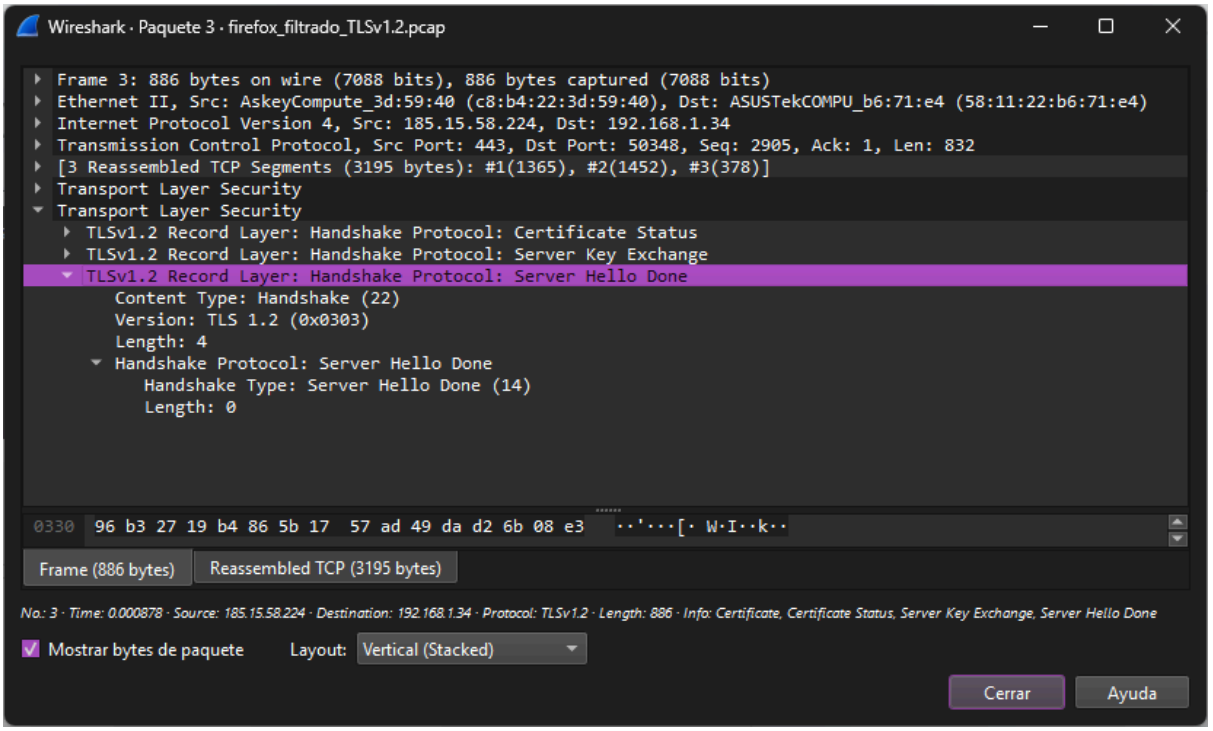
Podremos comprobar los valores de la certificación tales como el nombre del país (US), la provincia (California), la localidad (San Francisco), la organización (Wikimedia Foundation) y el nombre (wikipedia.org).
Vamos a comprobar ahora que esos valores se corresponden al certificado:



Y podemos comprobar que efectivamente son los mismos valores asignados.

Analizamos el apartado de Server Hello Done, de él podemos comprobar distintos campos tales como:

- Content Type: Handshake (22) : este valor indica que el mensaje pertenece al protocolo de handshake TLS.
- Versión: TLS 1.2 (0x0303): especifica que el protocolo utilizado es TLS versión 1.2.
- Length: 4: indica la longitud total del contenido del mensaje.
- Handshake Type: Server Hello Done (14): este campo indica que el mensaje es de tipo "Server Hello Done".
- Length (Handshake Protocol): 0 : Este subcampo indica que el contenido adicional del mensaje "Server Hello Done" tiene una longitud de 0 bytes, lo cual es normal ya que este mensaje solo señala el final de la fase del servidor en el handshake.



4. Ver si ha habido diferencias en la elección de parámetros criptográficos dependiendo de los navegadores.

Vamos a analizar las únicas dos diferencias en la elección de parámetros criptográficos (se ha utilizado la versión 1.3 en los dos navegadores):

Ámbitos	Firefox	Chrome
Key_Share	Prioridad de asignación x25519 (Criptografía de curva elíptica con Curve 25519).	La misma, aunque añade un parámetro de Robustez (GREASE).
Cipher Suites	Tiende a incluir configuraciones más conservadoras. El orden de prioridad varía.	Chrome, por diseño, puede experimentar con configuraciones más agresivas.

Al ser navegadores muy parecidos y modernos, los dos utilizan parámetros muy parecidos, variando levemente las prioridades en cuanto a Cipher Suites y métodos de intercambio de claves.

5. Visualizar del minuto 40:00 al 53:00 (intervención de Ramón Onrubia) en el vídeo (*). ¿Puede deducirse que con Wireshark pueden obtenerse fácilmente contraseñas de usuarios de un equipo?. Razone según lo que se ve.

Podemos deducir que no, esto se debe a que aunque se interviniera y capturase la clave privada del servidor, el tráfico posterior-anterior a ese no podría descifrarse. Sin embargo, a través de ataques de tipo Man-in-the-Middle (MITM) o si se fuerza al cliente a usar protocolos inseguros (desactivando https) entonces Wireshark podría ser utilizado para interceptar contraseñas.

Además, los navegadores se defienden de estos ataques MITM con HSTS (Strict-Transport-Security), que consiste en una configuración de seguridad que puede ser incorporada en los sitios web para asegurar que el tráfico se realiza mediante un canal seguro.

Ramón Onrubia nos demuestra cómo realizar una captura de credenciales a través de Wireshark con un script desde distintos sistemas operativos, lo hace parecer sencillo. Aun así, solo es posible realizarse si estamos en uno de los dos endpoints, ya sea en el cliente, o en el servidor, y habiendo indicando al navegador la variable de entorno.

En conclusión, es casi imposible obtener contraseñas de usuarios sin acceso adicional al servidor o a las claves privadas necesarias para descifrar el tráfico.